

SOC Fundamentals Document

Prepared for Cybersecurity Project

August 6, 2025

Contents

1	Implement and Explain Advanced Cybersecurity Defense Strategies	2
1.1	Application of Zero Trust Architecture	2
1.2	Explanation of Defense in Depth	2
1.3	Supply Chain Security Demonstration	2
1.4	Description of an Advanced Security Model	3
2	Implement Incident Response and Handling	4
2.1	Incident Response Plan (IRP)	4
2.2	Digital Forensics Basics	4
2.3	Evidence Collection and Documentation	4
2.4	Incident Triage and Prioritization	4
2.5	Post-Incident Analysis	5
3	Demonstrate SOC (Security Operations Center) Fundamentals	6
3.1	SOC Functions and Operations	6
3.2	Monitoring Fundamentals	6
3.3	Alert Management	6
3.4	Basic Threat Detection	6
4	Develop and Implement Security Policies and Governance	7
4.1	Policy Development Framework	7
4.2	Governance Structure	7
4.3	Compliance Requirements	7
4.4	Policy Implementation	7
5	Produce Effective Security Documentation	8
5.1	Technical Writing	8
5.2	Process Documentation	8
5.3	Security Playbooks	8
5.4	Knowledge Base Management	8

1 Implement and Explain Advanced Cybersecurity Defense Strategies

1.1 Application of Zero Trust Architecture

Zero Trust Architecture (ZTA) operates on the principle of “never trust, always verify,” assuming that threats can exist both inside and outside the network. In this project, ZTA was applied to a hypothetical enterprise network system.

Access controls were enforced across at least two security layers:

Network Layer Micro-segmentation was implemented using software-defined networking (SDN) tools like Cisco ACI. All east-west traffic between servers was inspected, with identity-based access controls verifying user credentials and device health before allowing communication. For example, access to a database server from an application server required multi-factor authentication (MFA) and continuous monitoring for anomalies. Application Layer API gateways (e.g., using Kong or AWS API Gateway) enforced granular access policies. Each API call was authenticated via JWT tokens, and least-privilege principles were applied, ensuring users could only access endpoints relevant to their role.

This setup prevented lateral movement by attackers, as no implicit trust was granted based on network location.

1.2 Explanation of Defense in Depth

Defense in Depth (DiD) is a layered security approach that uses multiple controls to protect assets, ensuring that if one layer fails, others remain effective. In the system architecture—a web application hosted on a cloud infrastructure (e.g., AWS)—at least three layers were applied:

1. Perimeter Defense Layer: Firewalls and intrusion detection systems (IDS) like Snort were deployed at the network edge to filter incoming traffic. For instance, rules blocked known malicious IP addresses and scanned for exploits targeting web vulnerabilities like SQL injection.
2. Host Defense Layer: Endpoint protection platforms (EPP) such as Microsoft Defender were installed on servers and workstations. This included antivirus scanning, host-based firewalls, and application whitelisting to prevent unauthorized software execution. In the architecture, servers ran hardened OS configurations with regular vulnerability scans using tools like Nessus.
3. Data Defense Layer: Encryption was enforced using AES-256 for data at rest (via AWS S3 encryption) and in transit (TLS 1.3). Access to sensitive data required role-based access control (RBAC) integrated with identity providers like Okta, ensuring data integrity and confidentiality even if outer layers were breached.

These layers collectively reduced the attack surface and provided redundancy in protection.

1.3 Supply Chain Security Demonstration

Supply chain risks involve vulnerabilities introduced through third-party vendors or components. In this project, an example was identified in the use of open-source libraries for

the web application.

Risk Identification During a software bill of materials (SBOM) analysis using tools like OWASP Dependency-Check, a vulnerability (CVE-2021-44228, Log4Shell) was found in an outdated Log4j library sourced from a public repository. **Mitigation** The library was updated to the latest patched version (2.17.1). Additionally, vendor risk assessments were conducted, including code reviews and requiring signed binaries from suppliers. A policy was established to scan all third-party components quarterly, and alternative suppliers were evaluated to diversify dependencies.

This mitigated the risk of remote code execution exploits via the supply chain.

1.4 Description of an Advanced Security Model

The Bell-LaPadula (BLP) model was selected as the advanced security model. BLP focuses on confidentiality through mandatory access control (MAC), enforcing “no read up” (simple security property) and “no write down” (star property) rules to prevent information leakage from higher to lower security levels.

In application to secure a classified document management system:

- Subjects (users) and objects (documents) were assigned security labels (e.g., Top Secret, Secret, Unclassified).
- A user with “Secret” clearance could read “Secret” or “Unclassified” documents but not “Top Secret” (no read up).
- The same user could write to “Secret” or higher levels but not lower (no write down), preventing downgrading of sensitive data.
- Implementation used SELinux on Linux servers to enforce these policies, with audit logs tracking access attempts.

This model ensured data confidentiality in multi-level security environments.

2 Implement Incident Response and Handling

2.1 Incident Response Plan (IRP)

The IRP follows a structured 5-step framework:

1. Preparation: Establish an incident response team (IRT) with roles like incident commander and forensic analyst. Develop tools, communication plans, and conduct regular tabletop exercises. For example, maintain an inventory of critical assets and baseline network behavior.
2. Identification: Monitor for anomalies using SIEM tools like Splunk. Upon detection (e.g., unusual login attempts), classify the event as an incident based on predefined thresholds.
3. Containment: Isolate affected systems, such as quarantining a compromised endpoint via EDR tools like CrowdStrike. Short-term containment might involve disabling accounts; long-term could include network segmentation.
4. Eradication: Remove threats by deleting malware, patching vulnerabilities, and rebuilding systems from clean backups. Use antivirus scans and rootkit detectors.
5. Recovery: Restore operations gradually, monitoring for re-infection. Validate system integrity and communicate status to stakeholders.

2.2 Digital Forensics Basics

Digital forensics was demonstrated using Volatility, a memory forensics tool, for data collection. In a simulated incident involving a memory-resident malware:

- Volatility was run on a memory dump (acquired via tools like DumpIt) with commands like `vol.py -f memdump.raw --profile=Win10x64 pslist` to list processes and identify suspicious ones, such as unauthorized executables.

This collected volatile data without altering the evidence.

2.3 Evidence Collection and Documentation

Two forms of evidence were collected with chain of custody:

1. Log Files: System logs from Windows Event Viewer were exported, showing failed login attempts. Chain of custody: Documented with timestamps, collector's name (e.g., Analyst John Doe), and cryptographic hashes (SHA-256) for integrity.
2. Screenshots: Captures of alert dashboards in Splunk during the incident. Chain of custody: Stored in a sealed digital envelope with metadata logs tracking access and transfers.

All evidence was stored in a secure repository with access logs.

2.4 Incident Triage and Prioritization

Incidents were categorized by severity and business impact:

1. High Severity (Critical Impact): Ransomware attack encrypting production servers—prioritized first due to potential data loss and operational downtime.
2. Medium Severity (Moderate Impact): Phishing email leading to credential compromise—handled next, as it could escalate but doesn't immediately halt operations.
3. Low Severity (Low Impact): Unauthorized port scan from external IP—monitored but deprioritized unless persistent, as it poses minimal immediate threat.

Triage used a scoring system: Severity (1–5) $\times$ Impact (1–5).

2.5 Post-Incident Analysis

In a simulated phishing incident, the outcome was contained without data exfiltration. Lessons learned:

1. Improve user training on phishing recognition, as the incident stemmed from a clicked malicious link.
2. Enhance email filtering rules in tools like Microsoft Exchange to block similar threats proactively.

These were documented in a lessons-learned report for future IRP updates.

3 Demonstrate SOC (Security Operations Center) Fundamentals

3.1 SOC Functions and Operations

SOC oversees continuous monitoring, threat detection, and response. Three primary roles:

1. SOC Analyst (Tier 1): Monitors alerts, performs initial triage, and escalates issues. Responsibilities include reviewing SIEM dashboards and basic investigations.
2. Incident Responder (Tier 2): Investigates escalated alerts, contains threats, and coordinates with teams. Handles forensics and malware analysis.
3. SOC Manager: Oversees operations, defines metrics (e.g., mean time to response), and ensures compliance. Manages training and tool integrations.

3.2 Monitoring Fundamentals

Monitoring was configured using Wireshark, a packet capture tool.

Configuration Installed on a monitoring server, set to capture on the primary network interface with filters like “tcp.port == 80 or tcp.port == 443”.

Two types of network activity monitored:

1. HTTP/HTTPS Traffic: Captured web requests to detect unencrypted data or suspicious domains.
2. Anomalous Port Scans: Monitored for unusual TCP SYN packets indicating reconnaissance.

3.3 Alert Management

Two security alerts were generated, investigated, and resolved:

1. Alert 1: Brute-Force Login Attempts: Generated in SIEM (e.g., ELK Stack) from repeated failed logins. Investigation: Reviewed logs, traced IP to a known botnet. Resolution: Blocked IP via firewall and reset affected passwords.
2. Alert 2: Malware Download: Detected via IDS signature match. Investigation: Analyzed payload with VirusTotal. Resolution: Isolated endpoint and removed file using antivirus.

3.4 Basic Threat Detection

A threat—DDoS attack—was identified via SOC tools. Detection: Splunk query showed traffic spikes (>10x normal) from multiple IPs targeting the web server. Analysis: Correlated with IDS logs; mitigated by rate-limiting in the WAF (Web Application Firewall).

4 Develop and Implement Security Policies and Governance

4.1 Policy Development Framework

Security Policy Document

1. Access Control Policy: Requires MFA for all remote access, RBAC for resources, and annual reviews. Prohibits shared accounts.
2. Data Protection Policy: Mandates encryption for sensitive data, regular backups, and data classification (e.g., public, internal, confidential).
3. System Use Policy: Outlines acceptable use, prohibiting personal software installation and requiring antivirus on all devices.

4.2 Governance Structure

Roles for enforcement:

- CISO: Oversees policy compliance and audits.
- IT Manager: Implements technical controls.
- HR: Handles training and disciplinary actions for violations.

4.3 Compliance Requirements

References NIST Cybersecurity Framework (CSF), aligning policies with Identify, Protect, Detect, Respond, and Recover functions. For example, access controls map to PR.AC (Access Control).

4.4 Policy Implementation

Policies were communicated via company-wide emails and training sessions. Enforcement: Integrated into systems, e.g., access control via Active Directory group policies. Evidence: Audit logs showing policy violations and remediations.

5 Produce Effective Security Documentation

5.1 Technical Writing

Cybersecurity Procedure Document: Firewall Rule Implementation

1. Assess needs: Identify assets and threats.
2. Define rules: E.g., allow TCP/443 inbound from trusted IPs.
3. Configure: Use firewall console (e.g., pfSense) to add rules.
4. Test: Simulate traffic to verify.
5. Document: Log changes and review annually.

5.2 Process Documentation

Step-by-Step Guide: Patch Management

1. Identify patches: Scan systems with WSUS or Nessus.
2. Test: Apply in a sandbox environment.
3. Deploy: Schedule during off-hours using tools like SCCM.
4. Verify: Re-scan for vulnerabilities.
5. Report: Log outcomes and any issues.

5.3 Security Playbooks

1. Phishing Incident Scenario: Detect email, isolate user, scan device, educate, report.
2. Malware Infection Scenario: Quarantine system, run scans, eradicate, restore from backup, analyze root cause.

5.4 Knowledge Base Management

Structured repository (e.g., in Confluence):

1. Threat Intelligence: Articles on common vulnerabilities (e.g., CVE database links).
2. Tools Reference: Guides for Splunk and Wireshark.
3. Policies: Full policy documents and FAQs.